

Security Monitoring

The attacker never sleeps

Monitor all entry points:

- logins, public available services, data storage locations, remote access

React to security events:

- Account access, firewall rule base, additional scanning

Status dashboards:

- get the status of a whole system at a glance

Monitor computing resources:

Locations of logins, Server monitoring - like service activity backups and software versions etc

Applications:

- Availability - Uptime and response times
- Data transfers, increased or decreased rates
- Security notifications from dev or manufacturer

Also infrastructure:

- Remote access systems - Employees, vendors, guests
- Firewall and IPS reports - Inc tease or type of attack

Log aggregation:

SIEM (Security Information and Event Manager):

- This consolidates all log info
- Centralized reporting
- Correlation between diverse systems

Scanning:

A constantly changing threat landscape:

- New vulnerabilities discovered daily
- Many different business apps and services
- Systems and people always moving

Actively check systems and devices:

- OS types and versions
- Device driver versions etc

Gather the raw details:

- Valuable database info

Reporting:

Analyze the collected data:

- Create actionable reports

Status information:

- Number of devices up to date/in compliance
- Devices running older OS

Determine next steps:

- New Vulnerability
- How many systems are vulnerable

Ad hoc information summaries:

- Prepare for the unknown

Archiving:

It takes an average of about 9 months for a company to identify and contain a breach:

- IBM security report, 2022

Access to data is critical:

- Archive over an extended period:

May have a mandate:

- State or fed law
- Or org requirements

Alerting:

Real time notification of security events:

- Increases in authentication errors
- Large file transfers

Actionable data;

- Keep the right people informed
- Enable quick response and status info

Notifications:

- SMS
- Email
- Security console / SOC

Quarantine:

- A foundational security response
- Prevent a potential security issue from spreading

Alert tuning;

- A balancing act
- Prevent false positives and false negatives

Security Tools

Security Content Automation Protocol (SCAP):

Many different tools on the market:

- NGFWs, IPS, vulnerability scanners, etc.
- They all have their own way of evaluating a threat

NIST National institute of standards and technology

How tools to identify and act on the same criteria:

- Validate the security configuration.
- Confirm patch installs
- Scan for a security breach

Using SCAP:

Scap can be shared between tools:

- Focused on configuration compliance
- Easily detect applications with known vulnerabilities

Especially useful in large environments :

- Many different operating systems and applications

This spec standard enables automation:

- Even between different tools

Automation types:

- Ongoing monitoring
- Notification and alerting
- Remediation and non compliant systems

Benchmarks:

Apply security best practices to everything:

- OS, Cloud providers, mobile devices, etc.
- The bare minimum for security settings

Example: Mobile Device:

- Disable screenshots, disable screen recording, prevent voice calls when locked, force encryption backups, disable additional VPN profiles, configure a lost phone message etc

Agent/agentless:

Check to see if the devices is in compliance;

- Install a software agent onto the device
- Run an on demand agent less check

Agents can usually provide more detail:

- Always monitoring for real time notifications
- Must be maintained and updated

Agentless runs without a formal install:

- Perform the check
- Doesn't require updates obviously

SIEM:

Security Information and Event Management

Log Collection of security alerts:

- Real time information

Log aggregation and long term storage

Data correlation

Forensic analysis

Antivirus / Antimalware:

- Refers specifically to a type of malware
- Trojans worms macro virus

DLP Data loss prevention:

Where's your data?;

- Social security numbers credit cards etc

Stop the data before attacker grabs it

So many sources and destinations:

- Endpoint clients and cloud based systems

SNMP (Simple network management protocol):

- A database of data (MIB) - Management information Base
- The database contains OIDs - Object identifiers - groups of numbers
- Poll devices over udp/161

Request statistics from a device:

- Server, firewall, workstation etc

Poll devices at fixed intervals:

- Create historical reports

SNMP traps:

Most SNMP operations expect a poll:

- Devices then respond to the SNMP request
- This requires constant polling

SNMP traps can be configed on the monitoring device:

- Communicates over UDP/162

Set a threshold for alerts:

- If the number of CRC errors increases by 5, send a trap
- Monitoring station can react immediately

NetFlow:

Gather traffic stats from all traffic flows:

- Shared communication between devices

Net Flow:

- Standard collection method
- Many products and options

Probe and collector:

- Probe watches network communication
- Summary records are sent to the collector

Usually a separate reporting app:

- Closely tied to the collector

Vulnerability scanners:

Usually minimally invasive

Port scans

Identify systems

Test from the outside and inside

- Don't dismiss insider threats

Gather as much info as possible